SOFTWARE REQUIREMENTS SPECIFICATION

PolicyPilot

A Permission-Aware, Evaluated Enterprise Knowledge Assistant

Item	Detail
Standard	IEEE 830-1998 (Recommended Practice for SRS)
Version	0.1 (Concise draft for review)
Date	October 16, 2026
Prepared by	Abdul Rauf
Source document	PolicyPilot Revised Project Proposal (October 16, 2026)
Status	Draft. Items marked TBD are listed in Appendix A.

1. Introduction

1.1 Purpose

This document specifies the requirements for PolicyPilot, a retrieval-augmented generation (RAG) assistant that answers employee questions from company policy documents, with citations, while ensuring that every retrieved passage is authorized for the requesting user. It is intended for the developer, reviewers, and anyone who must reproduce or evaluate the system.

1.2 Scope

PolicyPilot is a portfolio-grade service with a web interface, REST API, automated tests, containerized deployment, tracing, and a reproducible evaluation framework. It will:

- ingest and index a public handbook corpus with synthetic visibility labels;
- answer questions using hybrid retrieval, reranking, cited generation, claim verification, and abstention;
- enforce permissions on the server before any text reaches the language model;
- measure retrieval quality, answer quality, leakage, injection resistance, latency, and cost.

Out of scope: fine-tuning or training models, real identity-provider integration, production security certification, multi-tenant hardening, and full human case management for escalations. Test results are evidence about defined scenarios only and do not prove universal security.

1.3 Definitions, acronyms, and abbreviations

Term	Meaning
RAG	Retrieval-augmented generation: an LLM answers using passages retrieved from a document store.
Chunk	A heading-aware section of a document that is indexed and retrieved as one unit.
Permission	A content access category: Public, Employee, Manager, HR, or Finance.
System role	A functional role (Admin, Evaluator) that controls system features, not content access.
Hybrid retrieval	Combined keyword (BM25) and vector search.
Reranker	A cross-encoder that rescores retrieved candidates.
Abstention	Declining to answer because evidence is insufficient.
Recall@k, MRR	Retrieval metrics: coverage of relevant passages in top k; mean reciprocal rank.
p50 / p95	50th and 95th percentile latency.
TBD	To be decided; tracked in Appendix A.

1.4 References

- PolicyPilot Revised Project Proposal, Abdul Rauf, October 16, 2026.
- IEEE Std 830-1998, Recommended Practice for Software Requirements Specifications.

1.5 Document conventions

Requirements use "shall" and carry a unique ID in the form FR-<MODULE>-<NN> (functional) or NFR-<AREA>-<NN> (non-functional). Priority: M = Must (needed for the core system), S = Should (important, deferrable if schedule slips), C = Could (optional).

2. Overall Description

2.1 Product perspective

PolicyPilot is a standalone system. A Streamlit front end calls a FastAPI backend, which queries a Weaviate search database, a local embedding model and cross-encoder reranker, and a hosted LLM API used for generation and claim verification. Authorization is enforced by the backend, independently of the verifier. The verifier is a quality-control stage and is not a security boundary.

2.2 Product functions (summary)

- Ingest documents and index chunks with permission metadata.
- Authenticate demo users and resolve permissions on the server.
- Retrieve authorized passages (hybrid search, then reranking).
- Generate cited answers and verify each claim against its evidence.
- Abstain or escalate when evidence is inadequate.
- Run evaluation, security, and injection test suites and report results.
- Record traces, latency, and cost.

2.3 User classes and permissions

Two independent concepts are used. Content permissions decide which documents a user may read. System roles decide which features a user may use. A user may hold several content permissions at once (for example HR and Manager); effective access is the union of all assigned permissions. Public content is visible to everyone, and Employee is the baseline for every authenticated user.

User class	Type	Description
Employee	Content permission	Baseline user. Reads Public and Employee content.
Manager	Content permission	Adds Manager content. Does not imply HR or Finance.
HR staff	Content permission	Adds HR content. Does not imply Manager or Finance.
Finance staff	Content permission	Adds Finance content. Does not imply Manager or HR.
Admin	System role	Manages users, permissions, and ingestion runs. Does not gain access to restricted content unless also assigned that content permission.
Evaluator	System role	Runs evaluation and security suites and views result reports. Content access follows assigned permissions only.

Example: a user with Employee + Manager + HR can read Public, Employee, Manager, and HR content, but not Finance content.

2.4 Operating environment

- Docker Compose deployment on a developer machine; optional low-cost hosted demo.
- Python 3 with FastAPI; Streamlit interface; Weaviate search database.
- Hosted LLM API for generation and judging; open-source embedding model and cross-encoder.
- GitHub Actions for continuous integration.

2.5 Design and implementation constraints

- Authorization shall be enforced on the server and shall deny by default.
- Retrieved documents are untrusted content and shall not override system policy.

- The corpus shall be used only after its licence and redistribution terms are verified.
- Model identifiers, prompts, parameters, and package versions shall be recorded for reproducibility.
- Effort budget is about 60 to 80 hours over four weeks; priority order is authorization, evaluation, answer reliability, deployment, polish.

2.6 Assumptions and dependencies

- Visibility labels are synthetic and are not the source organization's real classifications.
- The hosted LLM API is available and remains within the evaluation budget.
- Approximately 200 to 500 documents or sections are available for the corpus.
- Demo users and roles are created locally; no real identity provider is used.

3. Specific Requirements

3.1 External interface requirements

3.1.1 User interface

- Streamlit web application with a login page, question box, answer panel, citation list, and status indicator.
- Admin page (users, permissions, ingestion) and Evaluator page (run suites, view results), shown only to users holding those system roles.

3.1.2 Software interfaces

- Weaviate: hybrid search with metadata filtering on allowed permissions.
- LLM API: answer generation and claim verification; model ID and parameters recorded per request.
- Embedding model and cross-encoder: loaded locally; exact identifiers TBD.

3.1.3 REST API (proposed)

Method	Endpoint	Access	Purpose
POST	/auth/login	Public	Authenticate and return a session token.
GET	/me	Authenticated	Return the user's effective permissions and system roles.
POST	/query	Authenticated	Ask a question; returns answer, citations, and status.
GET	/sources/{chunk_id}	Authenticated	Show a cited passage if authorized; otherwise a not-found response.
POST	/admin/ingest	Admin	Start an ingestion run.
GET	/admin/ingest/{run_id}	Admin	View run status and failures.
PUT	/admin/users/{id}/permissions	Admin	Change a user's content permissions.
POST	/eval/runs	Evaluator	Start an evaluation or security suite run.
GET	/eval/runs/{run_id}	Evaluator	Fetch results and metrics.
GET	/health	Public	Service health check.

Query response statuses: ANSWERED, PARTIAL (some claims removed or qualified), ABSTAINED, ESCALATED, and ERROR.

3.2 Functional requirements

3.2.1 Ingestion and indexing (ING)

ID	Requirement	Priority
FR-ING-01	The system shall ingest approved source documents and record source URL, retrieval date, licence note, and document version.	M
FR-ING-02	The system shall preserve headings and section structure and split documents into heading-aware chunks with a documented size and overlap.	M
FR-ING-03	The system shall give each chunk a stable document ID and chunk ID, plus source URL, section, version, update timestamp, and allowed permissions.	M
FR-ING-04	The system shall generate embeddings and index chunks for keyword and vector search.	M
FR-ING-05	The system shall reject any chunk with missing or invalid permission metadata and log the failure.	M
FR-ING-06	The system shall remove or replace indexed content when a source document is updated or deleted, leaving no stale chunks.	M
FR-ING-07	The system shall validate permission metadata and citation links before marking an ingestion run successful.	S

3.2.2 Authentication and authorization (AUTH)

ID	Requirement	Priority
FR-AUTH-01	The system shall authenticate demo users and issue a session token.	M
FR-AUTH-02	The system shall resolve a user's permissions on the server and shall ignore any role or permission supplied by the client.	M
FR-AUTH-03	A user's effective permissions shall be the union of all assigned content permissions; Public applies to all and Employee applies to all authenticated users.	M
FR-AUTH-04	A chunk shall be accessible only if the user holds at least one of the chunk's allowed permissions.	M
FR-AUTH-05	If identity or permission resolution fails, the system shall deny access.	M
FR-AUTH-06	Admin and Evaluator system roles shall not grant access to restricted content.	M
FR-AUTH-07	A permission change shall apply to the user's next request, with no stale access from sessions or caches.	M
FR-AUTH-08	Restricted content shall not appear in answers, citations, errors, logs, or cached responses for unauthorized users.	M
FR-AUTH-09	A response to a question whose only relevant evidence is restricted shall be indistinguishable from a response where no evidence exists.	M

3.2.3 Retrieval (RET)

ID	Requirement	Priority
FR-RET-01	The system shall run keyword and vector retrieval with the authorization filter applied inside the retrieval query.	M
FR-RET-02	The system shall recheck authorization of every candidate before passages are assembled into the LLM context.	M
FR-RET-03	The system shall combine keyword and vector results using hybrid fusion.	M

ID	Requirement	Priority
FR-RET-04	The system shall rerank permitted candidates with a cross-encoder and pass a fixed, documented number of passages to generation.	M
FR-RET-05	The system shall make chunking, retrieval mode (BM25, vector, hybrid), and reranking configurable so each can be evaluated separately.	S

3.2.4 Answer generation, verification, and abstention (GEN / VER)

ID	Requirement	Priority
FR-GEN-01	The system shall generate answers using only authorized retrieved passages and attach citations linking claims to document and section IDs.	M
FR-GEN-02	The system shall treat retrieved text as untrusted data; instructions inside documents shall not alter system policy or trigger tool actions.	M
FR-GEN-03	Any response cache shall key on the user's permission set so results are never shared across different permission sets.	M
FR-VER-01	The system shall split each answer into factual claims and check each claim against its cited evidence.	M
FR-VER-02	The system shall label each claim as supported, contradicted, or insufficiently supported.	M
FR-VER-03	The system shall remove or qualify unsupported claims, or abstain when evidence is inadequate.	M
FR-VER-04	The abstention threshold shall be configurable and calibrated on answerable and unanswerable questions.	M
FR-VER-05	The system shall return an ESCALATED status with a suggested next step when it cannot answer; no case-management workflow is required.	S

3.2.5 User interface and administration (UI)

ID	Requirement	Priority
FR-UI-01	The interface shall let a user log in, ask a question, and view the answer, citations, and status.	M
FR-UI-02	Each citation shall open the authorized source passage.	S
FR-UI-03	The interface shall display the logged-in user's effective permissions for demonstration.	C
FR-UI-04	An Admin shall be able to view users, change content permissions, and start ingestion runs.	S
FR-UI-05	An Evaluator shall be able to start evaluation runs and view result tables.	S

3.2.6 Evaluation framework (EVAL)

ID	Requirement	Priority
FR-EVAL-01	The system shall store a labelled evaluation set (about 60 questions) recording the question, expected answer or abstention, relevant passages, permitted roles, and category.	M
FR-EVAL-02	The system shall compute Recall@5, MRR, Precision@k, answer correctness, unsupported claim rate, citation correctness, and abstention precision and coverage.	M

ID	Requirement	Priority
FR-EVAL-03	The system shall run the security suite in Appendix B and report the number of tests and observed leaks.	M
FR-EVAL-04	The system shall run prompt-injection tests by attack category and report attempts and observed successes for baseline and defence configurations.	M
FR-EVAL-05	The system shall report p50 and p95 latency and estimated cost per 1,000 queries.	M
FR-EVAL-06	The system shall support separate development and frozen held-out question sets.	S
FR-EVAL-07	Each run shall store its configuration (models, prompts, parameters, versions) and export results in the reporting-template format.	S

3.2.7 Observability (OBS)

ID	Requirement	Priority
FR-OBS-01	The system shall trace each request through retrieval, reranking, generation, and verification with timings.	M
FR-OBS-02	Logs shall be structured and shall not contain restricted passages or secrets.	M
FR-OBS-03	The system shall record token usage and estimated cost per request.	S

3.3 Performance requirements

ID	Requirement	Priority
NFR-PERF-01	Latency targets (p50 and p95, with and without verification) shall be set after baseline measurement and fixed before the final evaluation run. Proposed starting point: p95 ≤ 10 s with verification (TBD).	M
NFR-PERF-02	Latency and cost shall be measured under a documented test setup (hardware, concurrency, models).	M

3.4 Logical database requirements

Entity	Key fields
Document	doc_id, title, source_url, retrieved_on, licence_note, version, allowed_permissions
Chunk	chunk_id, doc_id, section, text, embedding, version, updated_at, allowed_permissions (inherited from document unless overridden)
User	user_id, username, password_hash, content_permissions[], system_roles[]
Eval item	item_id, question, category, expected_answer or expect_abstain, relevant_chunk_ids[], permitted_roles[], split (dev or final)
Run record	run_id, type (ingest or eval), configuration snapshot, metrics, timestamps
Request log	request_id, user_id, status, timings, tokens, cost (no restricted text)

Access matrix (illustrative project policy). Users may hold several rows at once; effective access is the union.

User group	Public	Employee	Manager	HR	Finance
Employee	Allow	Allow	Deny	Deny	Deny
Manager	Allow	Allow	Allow	Deny	Deny

User group	Public	Employee	Manager	HR	Finance
HR staff	Allow	Allow	Deny	Allow	Deny
Finance staff	Allow	Allow	Deny	Deny	Allow
Manager + HR	Allow	Allow	Allow	Allow	Deny

3.5 Design constraints

Area	Decision
Search database	Weaviate (native hybrid BM25 + vector search with metadata filtering in one query).
Front end	Streamlit for the MVP (Python-only, fastest path, keeps effort on authorization and evaluation).
Backend	Python and FastAPI.
Models	One open-source embedding model, one cross-encoder, one hosted LLM; identifiers TBD and then frozen.
Operations	Docker Compose, GitHub Actions, structured logging, and a tracing tool.

3.6 Software system attributes

ID	Requirement	Priority
NFR-SEC-01	Passwords shall be stored as salted hashes; API keys and secrets shall be kept out of source control.	M
NFR-SEC-02	A hosted demo shall use HTTPS and contain only public content and synthetic users.	S
NFR-REP-01	The system shall start with documented Docker Compose commands, and pinned versions and model IDs shall be recorded in the repository.	M
NFR-REP-02	Another engineer shall be able to reproduce the baseline and final evaluation from repository instructions.	M
NFR-MNT-01	CI shall run unit, integration, and authorization tests and a subset of evaluation checks on every change.	M
NFR-MNT-02	Major design choices shall be recorded in a decision log linked to measurements.	S
NFR-COST-01	LLM usage shall have a budget cap; experiment runs shall be limited and embeddings cached where appropriate.	M
NFR-LEG-01	Corpus licence and redistribution terms shall be confirmed, and attribution retained, before data is published.	M
NFR-RPT-01	Reports shall give counts with percentages, state limitations, and describe results as preliminary where samples are small.	M

Appendix A. Open Issues (TBD)

These items are not yet decided and are to be agreed before the SRS is finalized.

#	Open item	Needed from
1	SRS metadata: university or organization, supervisor, final version number.	Author
2	Final corpus (for example GitLab Handbook) and licence confirmation.	Author
3	Embedding model, cross-encoder, and LLM identifiers.	Author, after short comparison
4	Numeric targets: latency, cost per 1,000 queries, retrieval and abstention goals.	Set after baseline
5	Rule for assigning synthetic visibility labels (share per category; document-level or chunk-level).	Author
6	Authentication method (proposed: username/password with signed token).	Author
7	Chunk size, overlap, and number of passages sent to generation.	Experiment in Week 1-2
8	Exact escalation behavior and message wording.	Author
9	Whether Admin can edit document-level permissions or only user permissions.	Author
10	Tracing tool choice and data retention period for logs.	Author
11	Optional extensions (Urdu queries, agentic retrieval, table-aware ingestion).	Decide after core is done

Appendix B. Minimum Security Test Scenarios

ID	Scenario	Related requirements
SEC-01	User requests a restricted document by its exact title.	FR-AUTH-04, FR-AUTH-09
SEC-02	Indirect question intended to reveal restricted information.	FR-RET-01, FR-RET-02
SEC-03	Permitted answer: every cited source is authorized for the user.	FR-AUTH-08, FR-GEN-01
SEC-04	Cached result requested by a user with a different permission set.	FR-GEN-03
SEC-05	Permission removed; later requests tested for stale access.	FR-AUTH-07
SEC-06	Retrieved document instructs the model to override policy or reveal secrets.	FR-GEN-02
SEC-07	Document tries to induce fabricated evidence or misleading citations.	FR-VER-01, FR-VER-02
SEC-08	Authentication or permission resolution fails; access must be denied.	FR-AUTH-05
SEC-09	Admin or Evaluator without the content permission requests restricted content.	FR-AUTH-06
SEC-10	Multi-permission user (Manager + HR) receives only the union of permitted content.	FR-AUTH-03

Appendix C. Traceability (objectives to requirements)

Project objective	Requirements	Evidence
End-to-end RAG over a permissioned corpus	FR-ING, FR-RET, FR-GEN	Demo, integration tests
Server-side authorization before the LLM context	FR-AUTH, FR-RET-01/02	SEC-01 to SEC-10
Compare chunking, BM25, vector, hybrid, reranking	FR-RET-03/04/05, FR-EVAL-02	Results table (App. D of report)
Measure unsupported claims and citation quality	FR-VER-01/02/03, FR-EVAL-02	Before/after verification
Calibrate abstention	FR-VER-03/04, FR-EVAL-02	Threshold trade-off table
Evaluate prompt-injection defences	FR-GEN-02, FR-EVAL-04	Attempts vs successes by category
Reproducible service with tests, tracing, cost reporting	FR-OBS, NFR-REP, NFR-MNT, FR-EVAL-05	CI results, latency and cost report